

ISMS ROLES & RESPONSIBILITIES

Classification: [internal/Public/confidential]

Use one of the following according to the needs with confirmation of required parties

version	Approved by	Owner	Date last updated	Review frequency	Next review	Comments

Table of Contents

Introduction.....	1
Purpose.....	1
Scope.....	1
Key Roles and Responsibilities	1
Responsibility assignment matrix	2

Introduction

Purpose

The purpose of this document is to define and assign the roles and duties within the Information Security Management System (ISMS) of *[Company Name]* in line with the ISO 27001 standard. This document strives to establish clear accountability and efficient management of information security across the organization. It provides a structure-based approach to preserving information assets by developing a framework for the deployment, maintenance, and ongoing development of the ISMS.

Scope

This document applies to all individuals and departments involved in the management, oversight, and execution of the ISMS within *[Company Name]*.

Key Roles and Responsibilities

Example:

Roles	Responsibilities
Project manager	Ensure the ISMS aligns with business objectives and complies with legal/regulatory requirements.
	Approve risk management policies and provide oversight on risk treatment decisions.
Chief Information Security Officer (CISO)	Oversee the overall security strategy and ensure all security risks are adequately identified and mitigated.
	Review and update the ISMS in line with evolving threats and business requirements.
Risk Assessment Lead	Conduct risk assessments, identifying potential threats, vulnerabilities, and impacts on information assets.
	Develop and maintain the risk register and treatment plans.

ISO 27001 toolkit

IT Manager	Implement technical security controls to mitigate identified risks, including network security, backups, and patching.
	Ensure secure configuration and monitoring of IT systems to minimize vulnerabilities.
Department Heads	Identify risks related to their specific departments and business processes.
	compliance with ISMS policies and procedures within their teams.
Compliance Officer	Ensure that all information security activities comply with applicable laws and contractual obligations.
	Advice on legal implications of security incidents and data breaches.
Human Resources Manager	Manage personnel security risks, including employee background checks and access control for sensitive data.
	Ensure employees receive adequate security awareness training.
Incident Response Team	Coordinate responses to security incidents and ensure appropriate measures are taken to contain and mitigate risks.
	post-incident reviews and update

Responsibility assignment matrix

A Responsibility Assignment Matrix (RAM) is a project management tool used to clarify and assign roles to individuals or departments involved in the *[Company Name]*. It helps ensure accountability by mapping tasks or deliverables to the responsible parties. RAM provides a clear visual of who **is responsible, accountable, consulted, and informed (RACI)** for each specific task or process.

Example RACI table:

Activity	Role 1(senior management)	Role 2(CISO)	Role 3(HR)	Role 4(Risk lead)
Approval of ISMS Policies	A	R	C	I
Risk Assessment and Evaluation	C	A	I	R
Security Awareness Training	C	R	A	I
Incident Response Plan Review	A	R	I	C

Explanation, for example activity scenarios

- Approval of ISMS Policies: Senior Management is Accountable (A) for final approval, while the CISO is Responsible (R) for writing and evaluating.
- Risk Assessment and Evaluation: Risk Lead is Responsible (R) for undertaking risk assessments, with the CISO being Accountable (A).
- Security Awareness Training: HR is Accountable (A) for overseeing staff training programs, while the CISO is Responsible (R) for supplying the security material.
- Incident Response Plan Review: CISO is Responsibility (R) for keeping up with the incident response plan, and Senior Management is Accountable (A) for enabling any changes.